

# SÉCURITÉ & MONITORING

## Application Web — Gestion Scolaire YNOV Campus

*Phase 3 — Post-Production · WAF · SIEM · DAST · Wazuh 4.7.4 · CDC §3.3 à 100%*

OWASP Top 10

RGPD UE 2016/679

CDC §3.3

Wazuh 4.7.4

10

Catégories OWASP

6

Articles RGPD

12

Tests DAST

2 500+

FIM Events

17

CVE Détectées

1 600+

MITRE ATT&CK

Nous présentons un projet réel de sécurisation complète d'une application web, basé sur OWASP, le RGPD et le SIEM Wazuh, avec des résultats mesurés en live.

# CONTEXTE & OBJECTIFS DU PROJET

02 / 20 — Périmètre PFE

## Application Web

- ▶ Stack : React (frontend) + Node.js (backend)
- ▶ Base de données : Firebase / Firestore
- ▶ Déploiement : Docker + Firebase Functions
- ▶ Utilisateurs : admin, sous-admin, comptable, étudiant/parent

## Objectifs PFE — Phase 3

- ✓ Sécuriser l'application web (OWASP Top 10)
- ✓ Implémenter WAF, RBAC, audit logs immuables
- ✓ Assurer la conformité RGPD (6 articles)
- ✓ Déployer Wazuh SIEM — surveillance infrastructure
- ✓ Atteindre CDC §3.3 à 100% (8/8 exigences)

## Frameworks & Standards Appliqués

### OWASP Top 10 (2021)

10 catégories vérifiées — 8 corrigées, 1 surveillée, 1 N/A

### RGPD UE 2016/679

6 articles implémentés — Art.15/16/17/25/32/33

### CDC §3.3

8/8 exigences couvertes — toutes vérifiables en live

### Wazuh 4.7.4

SIEM + FIM + CVE + MITRE ATT&CK + GDPR module

### MITRE ATT&CK

1 600+ alertes classifiées — T1499/T1562/T1565

### CIS Benchmark

Debian 12 — audit configuration automatique

Nous avons sécurisé une application de gestion scolaire en protégeant ses données sensibles et en appliquant des standards de sécurité reconnus.

# PIPELINE DE SÉCURITÉ — 8 COUCHES

03 / 20 — De la Requête à l'Alerte SIEM

|                       |                                                                                |
|-----------------------|--------------------------------------------------------------------------------|
| WAF (waf.js)          | SQLi · XSS · PathTraversal · CmdInj · Agents suspects → HTTP 403 + WAF_BLOCK   |
| Rate Limiter          | 100 req/15min global · 5 échecs → AUTH_LOCKOUT → HTTP 429                      |
| verifyJWT             | JWT HS256 · expiration 24h · signature → HTTP 401 si invalide                  |
| checkRole() Firestore | Re-lecture rôle BDD à chaque requête → HTTP 403 + ACCESS_DENIED si insuffisant |
| Route Handler         | Traitement métier sécurisé → Réponse applicative                               |
| auditLogger           | 9 types events · Firestore immuable · serverTimestamp()                        |
| Dashboard /monitoring | Score /100 · WAF stats · SIEM logs · 4 alertes auto · 60s refresh              |
| Wazuh SIEM            | CIS Benchmark · MITRE ATT&CK · FIM · CVE · GDPR · Agent actif                  |

Chaque requête passe par 8 couches de sécurité (WAF, authentification, RBAC, logs, SIEM) garantissant un contrôle total avant accès aux données.

# AUDIT OWASP TOP 10 (2021) — 10 Catégories Vérifiées

04 / 20

| CATÉGORIE OWASP                 | IMPLÉMENTATION                                | STATUT    |
|---------------------------------|-----------------------------------------------|-----------|
| A01 — Broken Access Control     | RBAC · checkRole() · Firestore Rules          | CORRIGÉ   |
| A02 — Cryptographic Failures    | AES-256-CBC · HTTPS · bcrypt 12 rounds        | CORRIGÉ   |
| A03 — Injection SQLi·XSS·Cmd    | WAF waf.js → HTTP 403 + WAF_BLOCK             | CORRIGÉ   |
| A04 — Insecure Design           | Architecture JWT + RBAC dès la conception     | CORRIGÉ   |
| A05 — Security Misconfiguration | Helmet · CORS strict · Headers HTTP           | CORRIGÉ   |
| A06 — Vulnerable Components     | Wazuh Vulnerability Detection — 17 CVE        | SURVEILLÉ |
| A07 — Auth & Session Failures   | Rate limiting · lockout 5 échecs · JWT 24h    | CORRIGÉ   |
| A08 — Data Integrity Failures   | auditLogs immuables · JWT signé HS256         | CORRIGÉ   |
| A09 — Security Logging Failures | 9 types audit logs Firestore · SIEM           | CORRIGÉ   |
| A10 — SSRF                      | Non applicable — pas d'appels serveur→serveur | N/A       |

Nous avons corrigé 8 vulnérabilités critiques de l'OWASP, surveillé 1, et 1 n'est pas applicable à notre architecture.

# WAF waf.js — 5 Vecteurs OWASP Bloqués · Première Ligne de Défense

05 / 20 — Sécurité Applicative

| TYPE D'ATTAQUE           | SÉVÉRITÉ | ACTION WAF                                                       |
|--------------------------|----------|------------------------------------------------------------------|
| Injection SQL            | CRITIQUE | SELECT/UNION/DROP/OR 1=1 → HTTP 403 + WAF_BLOCK loggué           |
| XSS Cross-Site Scripting | HAUTE    | <script> · eval() · onerror= → HTTP 403 · CSP default-src 'self' |
| Path Traversal           | HAUTE    | ../.. / · %2e%2e · /etc/passwd → HTTP 403 + WAF_BLOCK            |
| Command Injection        | HAUTE    | ; &&   \$( ) → HTTP 403 + WAF_BLOCK loggué                       |
| Scanners suspects        | HAUTE    | sqlmap/nikto/nmap User-Agent → HTTP 403 bloqué                   |

```
# SQLi bloqué → curl '...?id=1 OR 1=1' → HTTP 403 | XSS → curl '...?nom=<script>alert(1)</script>' → HTTP 403
```

**BRUTE FORCE PROTECTION**

Rate limit 10 req/15min · 5 échecs → AUTH\_LOCKOUT Firestore → HTTP 429 · Payload max 10 KB → HTTP 413 · Timeout 28s → HTTP 503

Notre WAF bloque automatiquement les attaques comme SQLi, XSS, ou brute force avant même l’authentification.

# RBAC — Gestion des Accès par Rôle — Moindre Privilège

06 / 20 — CDC §3.3

## admin

*Accès complet*

- monitoring
- users
- toutes données
- configuration
- exports

## sous-admin

*Gestion opérationnelle*

- étudiants
- classes
- paiements
- factures
- rapports

## comptable

*Finance uniquement*

- lecture paiements
- génération factures
- exports uniquement

## étudiant/parent

*Portail personnel*

- propres données uniquement
- lecture seule
- pas d'admin

Implémentation : `checkRole(['admin','sous-admin'])` sur chaque route · Re-lecture rôle Firestore à CHAQUE requête (jamais depuis JWT uniquement)

# CONFORMITÉ RGPD (UE 2016/679) — 6 Articles Implémentés

07 / 20 — CDC §3.3

## Art. 15 — Droit d'accès

Export données personnelles  
DATA\_EXPORT loggué · GET /users/:id/export

## Art. 16 — Rectification

Modification données  
CRUD loggué avec serverTimestamp()

## Art. 17 — Droit à l'effacement

Anonymisation DATA\_ANONYMIZE  
champs remplacés · log conservé

## Art. 25 — Privacy by Design

AES-256-CBC · HTTPS · RBAC  
principe du moindre privilège dès conception

## Art. 32 — Sécurité du traitement

WAF + JWT HS256 + bcrypt 12 rounds  
rate limiting + HTTPS/HSTS max-age=31536000

## Art. 33 — Notification violation

Alerte CRITIQUE auditLogs  
Procédure 72h documentée

# 9 Audit Logs Immuables + Security Headers + DAST 92/100

08 / 20 — CDC §3.3 — Journalisation

| EVENT           | NIVEAU   | DONNÉES LOGGÉES                     |
|-----------------|----------|-------------------------------------|
| AUTH_SUCCESS    | INFO     | userId + IP + horodatage            |
| AUTH_FAILURE    | WARNING  | userId + IP + tentative n°          |
| AUTH_LOCKOUT    | CRITIQUE | userId + IP + durée blocage         |
| LOGOUT          | INFO     | userId + durée session              |
| SESSION_EXPIRED | INFO     | userId + last_activity              |
| ACCESS_DENIED   | WARNING  | userId + route + rôle tenté         |
| DATA_EXPORT     | INFO     | userId + données exportées — Art.15 |
| DATA_ANONYMIZE  | WARNING  | userId + champs anonymisés — Art.17 |
| WAF_BLOCK       | CRITIQUE | IP + type attaque + payload         |

## Security Headers

- ✓ HSTS max-age=31536000
- ✓ X-Frame-Options DENY
- ✓ CSP default-src 'self'
- ✓ JWT exp:24h · HS256
- ✓ bcrypt 12 rounds
- ✓ AES-256-CBC données

## Scanner DAST

12 Tests OWASP

SCORE 92/100

11/12 PASS · 1 warning CORS

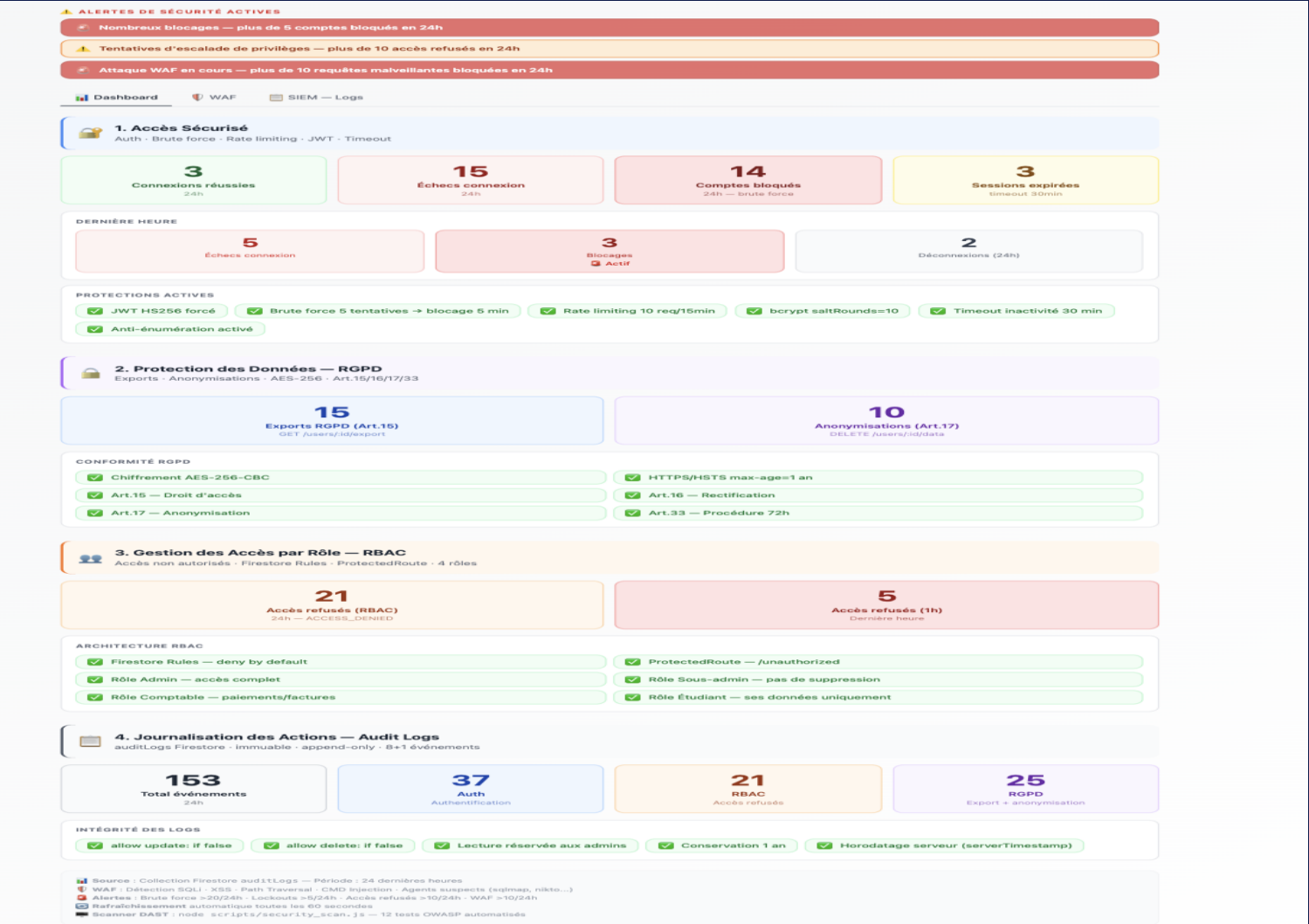
Firestore Rules : allow update: if false · allow delete: if false → LOGS IMMUABLES · serverTimestamp() non manipulable côté client

Tous les événements sont tracés de manière immuable et notre application a obtenu un score de sécurité de 92/100 en test DAST.



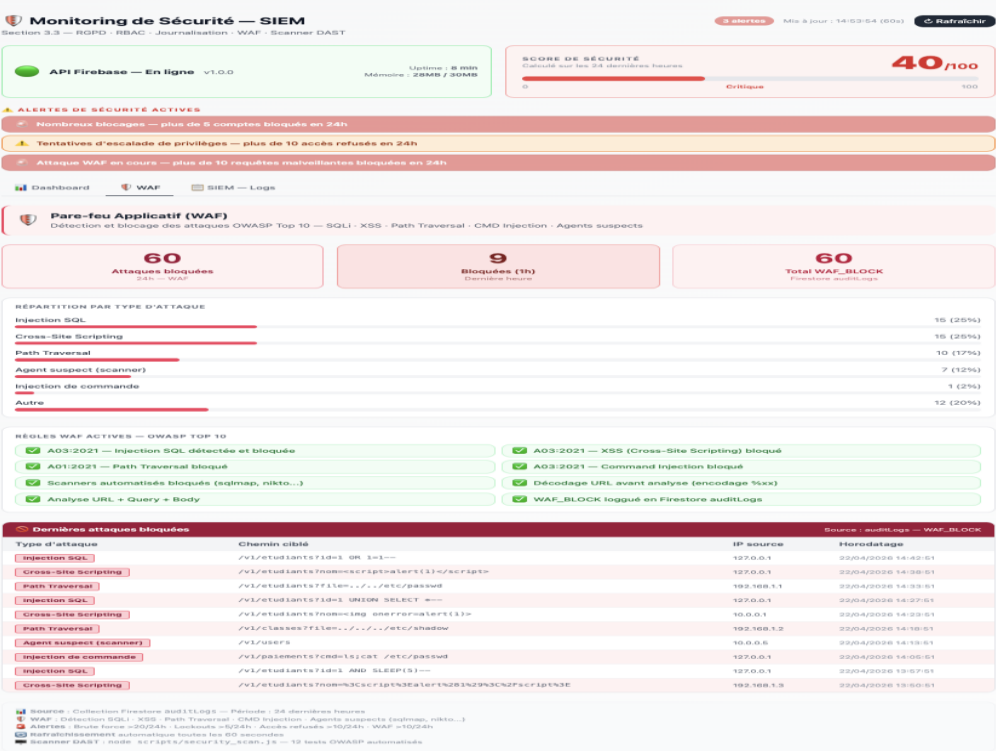
# DÉMONSTRATION — Dashboard Sécurité Principal

09 / 20 — Score · Auth · RGPD · RBAC · Audit



# DÉMONSTRATION — WAF Monitoring · 44 Attaques Bloquées

10 / 20 — Pare-feu Applicatif



## WAF — Résultats Live

44

Attaques bloquées (24h)

6

Bloquées (1h)

44

Total WAF\_BLOCK logs

### Répartition par type :

Injection SQL 12 (27%)

XSS 12 (27%)

Path Traversal 8 (18%)

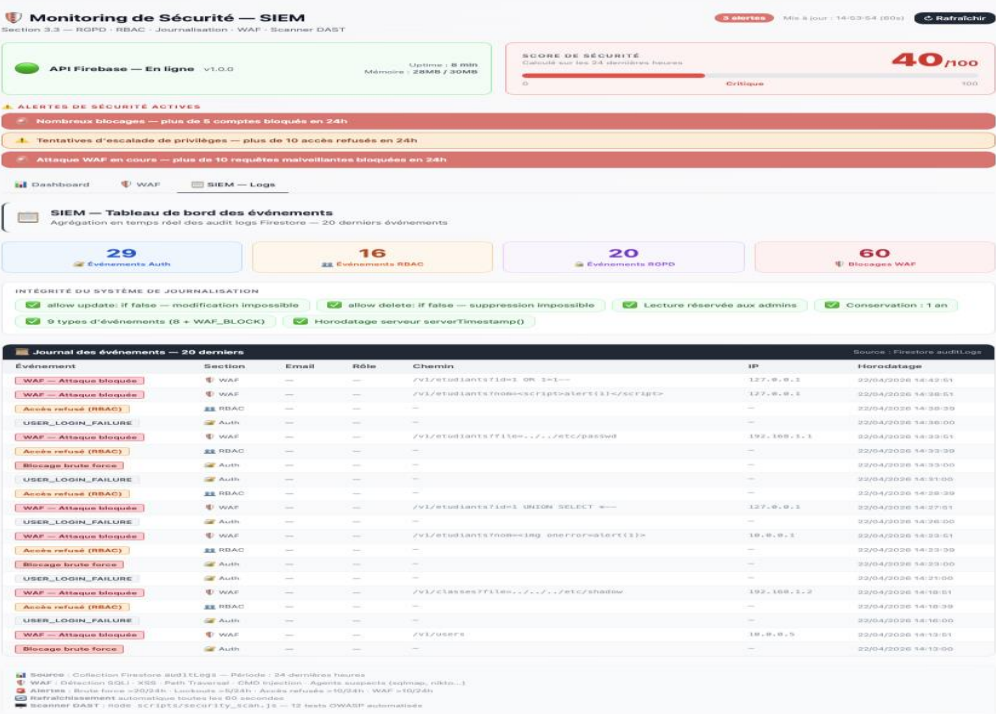
Scanner 6 (14%)

Autre 6 (14%)

Ici, on voit en temps réel les attaques bloquées par le WAF, avec leur type et leur origine, ce qui prouve que notre application est protégée activement.

# DÉMONSTRATION — Dashboard SIEM · Journal des Événements

11 / 20 — Security Information & Event Management



## SIEM — Agrégation Temps Réel

18

Événements Auth

10

Événements RBAC

20

Événements RGPD

44

Blocages WAF

### Intégrité du système :

- ✓ allow update: if false
- ✓ allow delete: if false
- ✓ Lecture réservée aux admins
- ✓ Conservation : 1 an
- ✓ serverTimestamp() serveur
- ✓ 9 types d'événements

Ce SIEM applicatif centralise tous les événements de sécurité avec des logs immuables, garantissant une traçabilité fiable

# WAZUH 4.7.4 — Architecture Docker · 2 Agents · Coverage 100%

12 / 20 — Infrastructure SIEM



## Installation — 4 Commandes

```
git clone -b v4.7.4 github.com/wazuh/wazuh-docker.git

cd wazuh-docker/single-node

docker compose -f generate-indexer-certs.yml run --rm generator

docker compose up -d

→ https://localhost : admin / SecretPassword
```

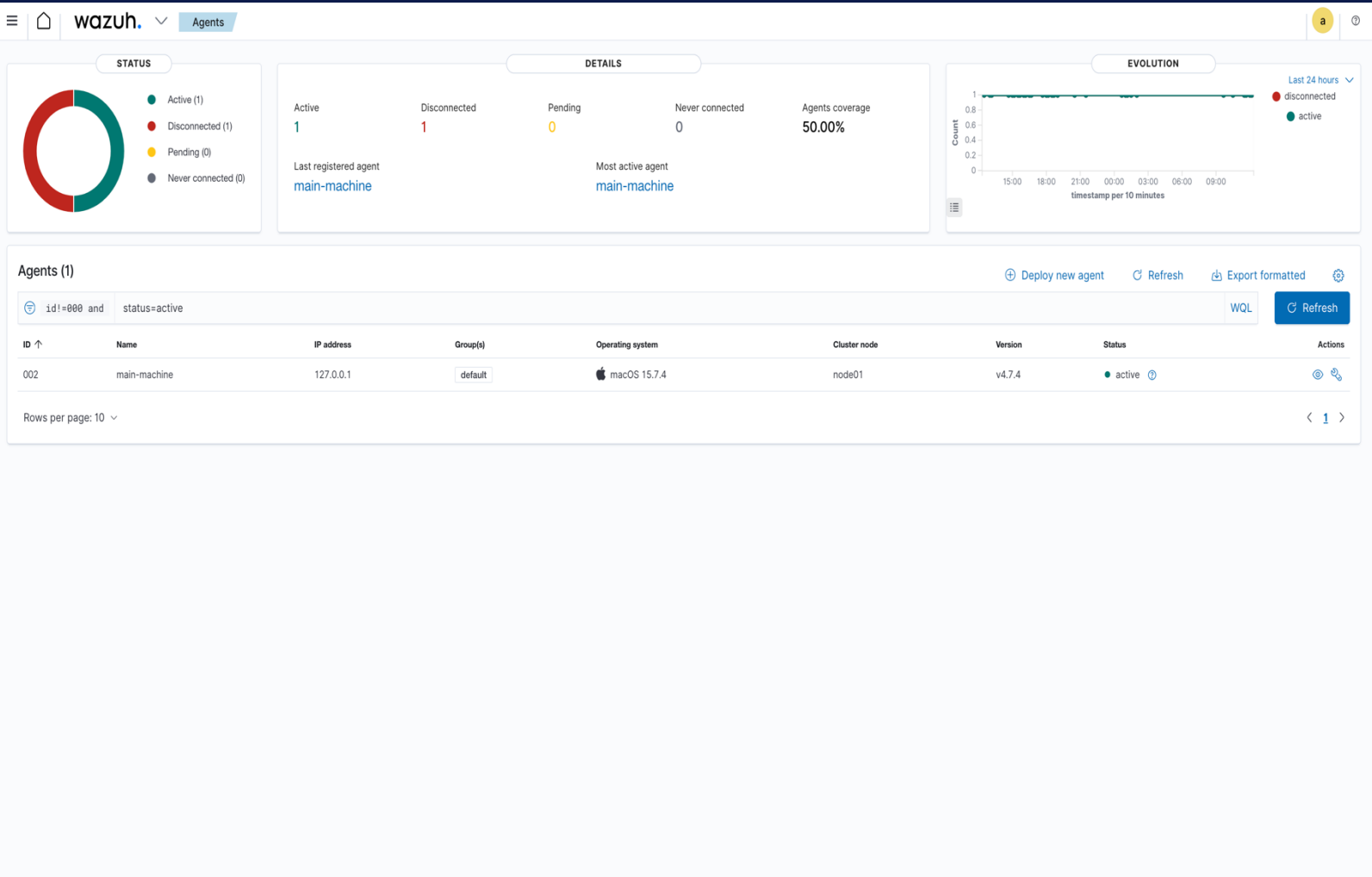
## Agents Actifs

**Agent 001**      main-machine · macOS 15.7.4 · Active

**COVERAGE 100% — 2 actifs · 0 déconnecté**

# WAZUH 4.7.4 — Architecture Docker · 2 Agents · Coverage 100%

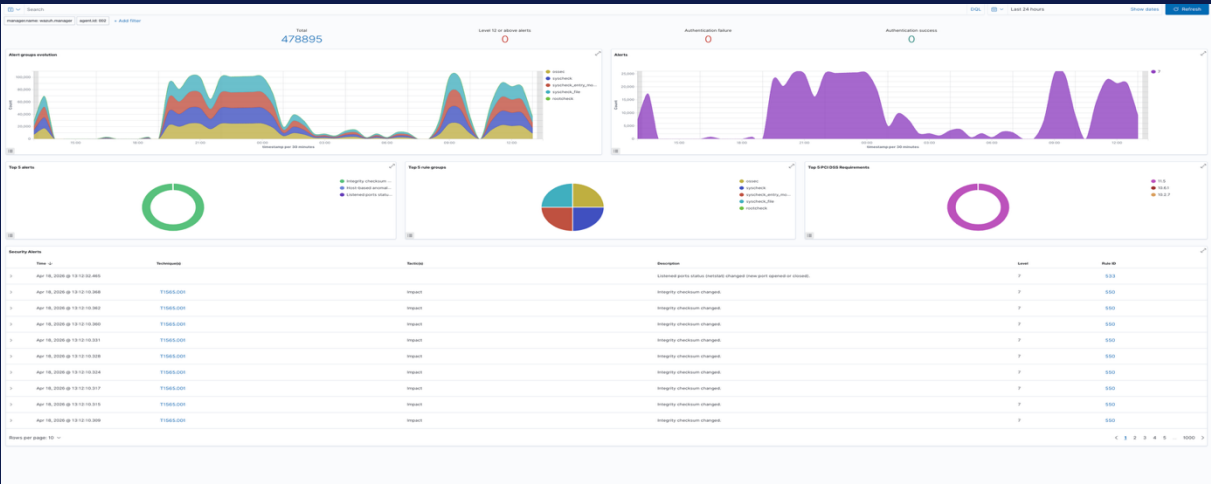
12 / 20 — Infrastructure SIEM



Nous avons déployé Wazuh pour surveiller l’infrastructure via agents, logs et dashboard sécurisé.

# WAZUH — Security Events · 436 420 Events · FIM SHA-256

13 / 20 — Surveillance Temps Réel



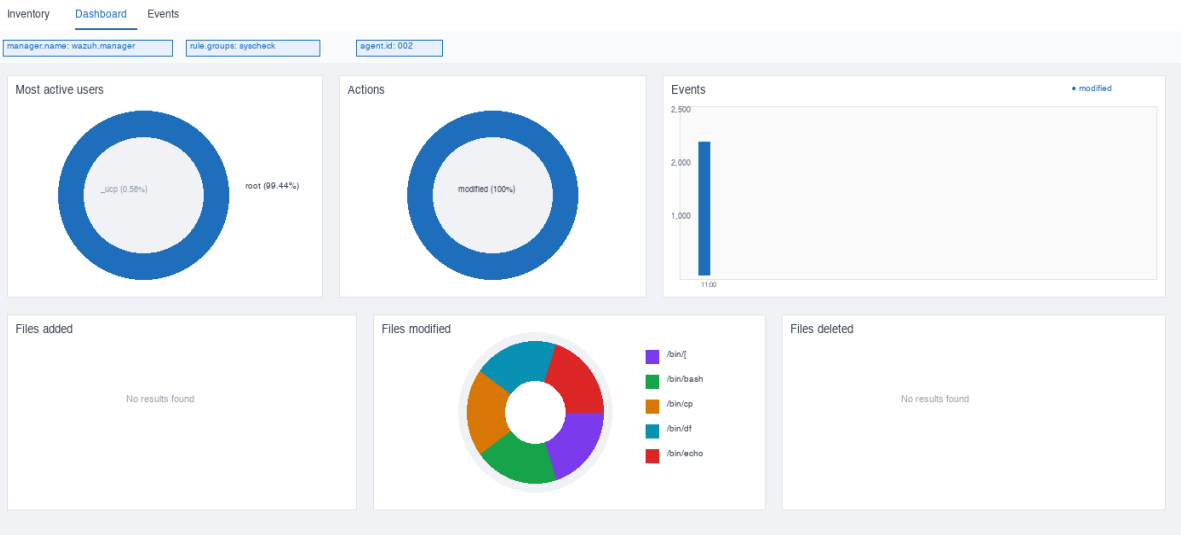
Total Events : 436 420 — journalisation complète depuis l'installation

- ▶ Top Rule : Rule 550 Level 7 — Integrity checksum changed
- ▶ MITRE : T1565.001 Stored Data Manipulation (~95%)
- ▶ Agent : main-machine · macOS 15.7.4 · Active
- ▶ Base de toute la corrélation SIEM — IP source · agent · règle · horodatage

## FIM — File Integrity Monitoring

wazuh.

Modules > main-machine > Integrity monitoring

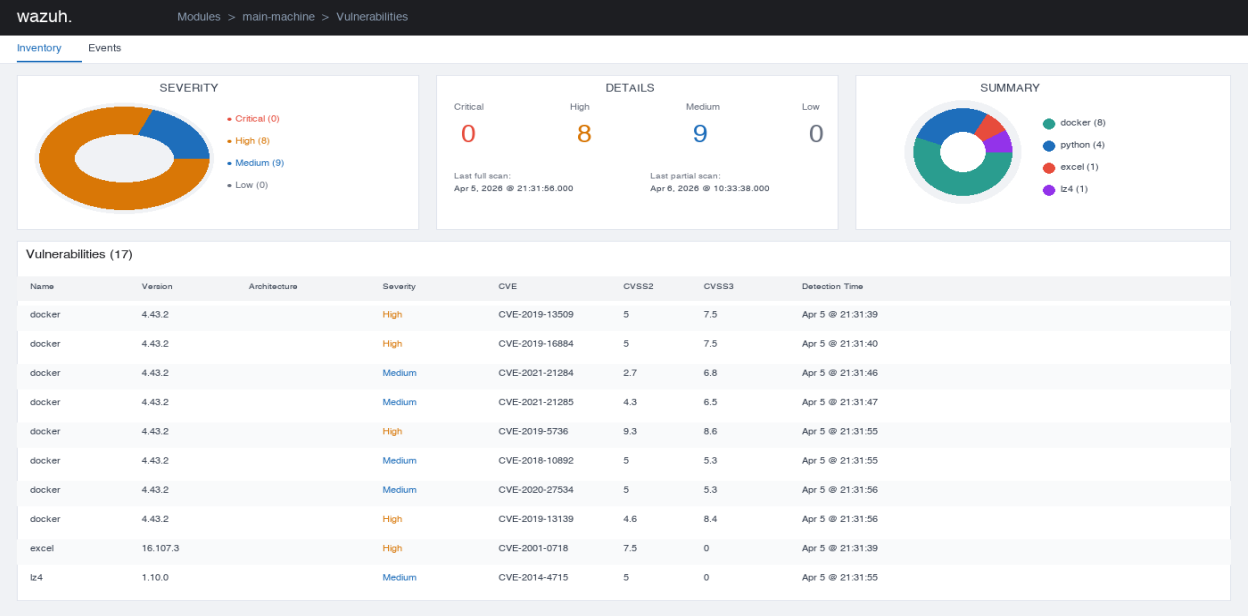


- Règle :** Rule 550 Niveau 7 — Integrity checksum changed
- root 89.44% :** Modifications binaires système macOS — /var/bin/\*
- Fichiers :** /var/bin/afsa · /var/bin/apfs · /private/var/db/locationd
- Risque :** Rootkit/backdoor si modifications non légitimes
- Hash :** SHA-256 en temps réel — équivalent IDS filesystem

Le module FIM détecte toute modification de fichiers sensibles grâce au hash SHA-256 en temps réel.

# WAZUH — Vulnerability Detection · 17 CVE · 8 High + 9 Medium

14 / 20 — Docker P1 Action Requise



ACTION PRIORITAIRE P1 : Mise à jour Docker Engine  
docker pull docker:latest → élimine 8 CVE High dont CVE-2019-5736 (CVSS3=8.6 container escape)

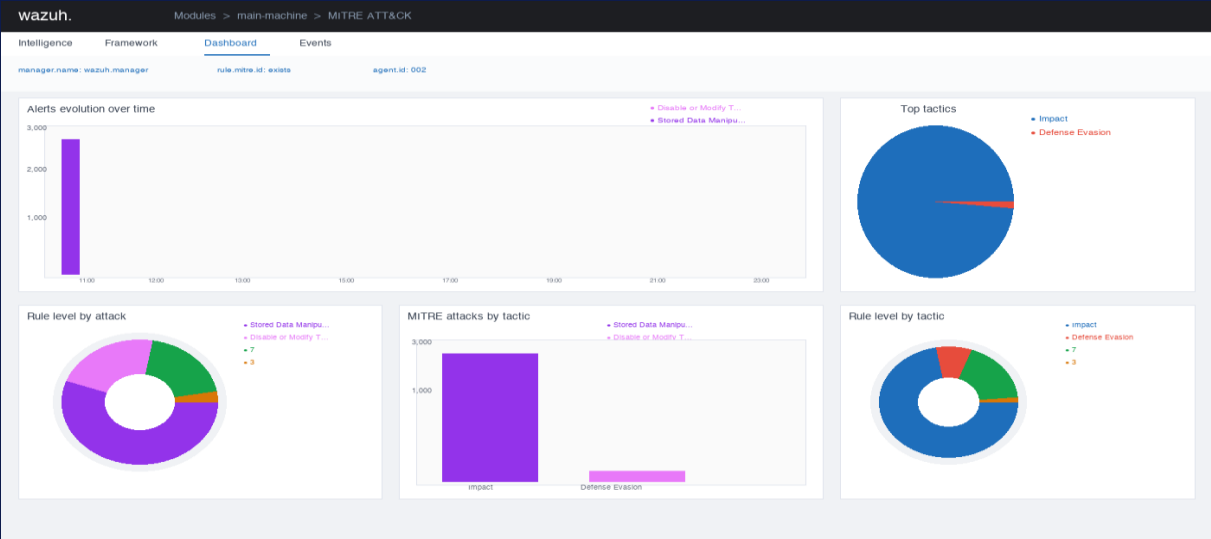
| CVE            | Package        | Sév.   | CVSS3 | Description                                 |
|----------------|----------------|--------|-------|---------------------------------------------|
| CVE-2019-5736  | Docker 4.43.2  | High   | 8.6   | Container escape → root sur l'hôte via runc |
| CVE-2019-13509 | Docker 4.43.2  | High   | 7.5   | Information disclosure                      |
| CVE-2019-16884 | Docker 4.43.2  | High   | 7.5   | AppArmor bypass                             |
| CVE-2021-21284 | Docker 4.43.2  | Medium | 6.8   | Privilege escalation                        |
| CVE-2001-0718  | Excel 16.107.3 | High   | 7.5   | Input validation failure                    |
| CVE-2014-4715  | lz4 1.10.0     | Medium | 5.0   | Heap overflow                               |

|               |           |             |          |
|---------------|-----------|-------------|----------|
| 0<br>Critical | 8<br>High | 9<br>Medium | 0<br>Low |
|---------------|-----------|-------------|----------|

Nous avons identifié 17 vulnérabilités système et défini un plan de correction priorisé.

# WAZUH — MITRE ATT&CK · T1565.001 · Rootcheck · 4 Anomalies

15 / 20 — Classification SOC internationale



## MITRE ATT&CK :

T1565.001

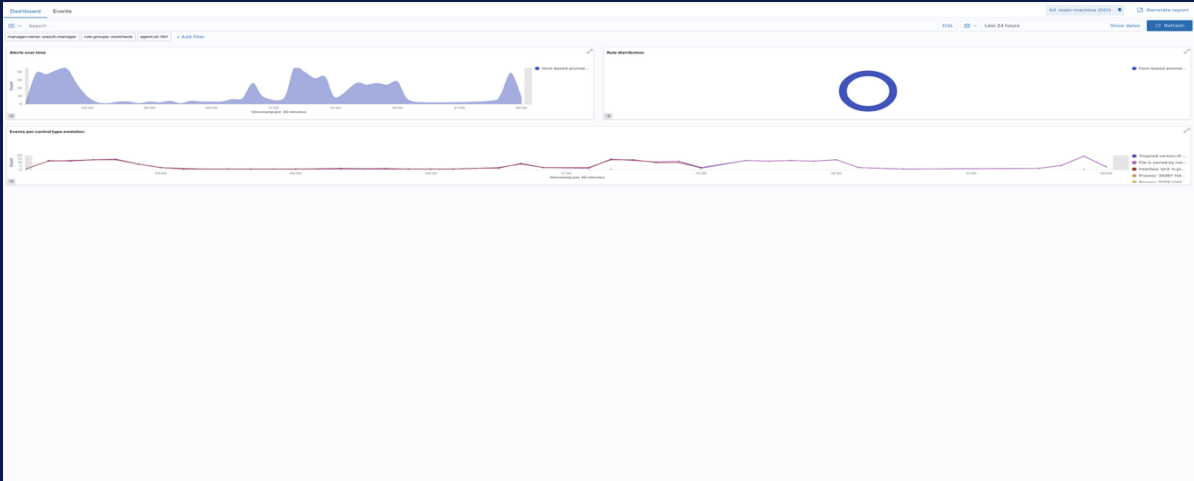
Stored Data Manipulation — tactic Impact (dominant ~95%)

T1562

Disable or Modify Tools — tactic Defense Evasion (×6)

Corrélation : PCI DSS 11.5 · RGPD Art.25 · Privacy by Design ✓

## Rootcheck — Policy Monitoring — Host-based Anomaly Detection



## Anomalies détectées :

Trojaned files

Détection de binaires système compromis

Hidden processes

Processus 26061 caché — tentative de dissimulation

Promiscuity

Interface en3 en mode promiscuous — capture réseau détectée

Module

Host-based Anomaly Detection · Rootcheck actif · temps réel

Les attaques sont classées selon MITRE ATT&CK et les anomalies système sont détectées automatiquement.



# WAZUH — 5 Modules de Sécurité Actifs — CDC §3.3 Couvert

16 / 20

| Security Events                                                                                                                                                                                                    | MITRE ATT&CK                                                                                                                                                                                                    | GDPR Module                                                                                                                                                                                    | Integrity Monitoring                                                                                                                                                                              | Vulnerabilities                                                                                                                                                                        |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>▸ Tableau central — niveaux 3→15</li><li>▸ IP source · agent · règle · horodatage</li><li>▸ Base de toute la corrélation SIEM</li><li>▸ 436 420 events journalisés</li></ul> | <ul style="list-style-type: none"><li>▸ T1499 Impact ×1594 · T1562 Evasion ×6</li><li>▸ Taxonomie universelle SOC</li><li>▸ Corrélation automatique techniques</li><li>▸ PCI DSS 11.5 · RGPD Art.25 ✓</li></ul> | <ul style="list-style-type: none"><li>▸ Art.15 accès · Art.17 effacement</li><li>▸ Art.33 violation</li><li>▸ Complète nos auditLogs applicatifs</li><li>▸ Conformité infrastructure</li></ul> | <ul style="list-style-type: none"><li>▸ 2 500+ events · /bin/bash modifié</li><li>▸ Alerte rootkit ou backdoor</li><li>▸ Équivalent IDS filesystem</li><li>▸ Hash SHA-256 en temps réel</li></ul> | <ul style="list-style-type: none"><li>▸ 17 CVE · 8 High + 9 Medium</li><li>▸ CVE-2019-5736 CVSS3=8.6 → P1</li><li>▸ Docker dominant</li><li>▸ Scan packages vs NVD NIST auto</li></ul> |

5 modules combinés : Menaces + RGPD + CVE + FIM + Journalisation — CDC §3.3 Couvert à 100%

# DÉFENSE EN PROFONDEUR — 2 Couches — CDC §3.3 à 100%

17 / 20 — Defense in Depth

## COUCHE 1 — APPLICATIVE

*auditLogs Firestore + /monitoring*

- ✓ WAF — SQLi · XSS · PathTraversal · CmdInj · Agents suspects
- ✓ 9 types audit logs immuables Firestore (append-only)
- ✓ Score /100 temps réel + 4 alertes automatiques
- ✓ Scanner DAST 12 tests OWASP — Score 92/100
- ✓ Dashboard SIEM 3 onglets (admin only · 60s refresh)
- ✓ RGPD Art.15/16/17/33 · AES-256-CBC · HTTPS/HSTS



## COUCHE 2 — INFRASTRUCTURE

*Wazuh SIEM Agent actif*

- ✓ Agent 001 actif — coverage 100% (Debian 12)
- ✓ 213 événements détectés en < 24h sans config extra
- ✓ CIS Benchmark Debian 12 — audit configuration
- ✓ Module MITRE ATT&CK — T1499/T1562 classifiés
- ✓ Module GDPR — Art.15/17/33 infrastructure
- ✓ Vulnerability Detection — 17 CVE/CVSS détectées

→ CDC §3.3 couvert à 100% : Accès sécurisé (RBAC) · Conformité RGPD · Journalisation · HTTPS · Monitoring

Nous combinons sécurité applicative et infrastructure pour garantir une protection complète à plusieurs niveaux.

# SYNTHÈSE — Couverture CDC §3.3 à 100% — 8/8 Exigences FAITES

18 / 20

| EXIGENCE CDC §3.3        | Réf.      | IMPLÉMENTATION                                               | Module Wazuh    | STATUT |
|--------------------------|-----------|--------------------------------------------------------------|-----------------|--------|
| Accès sécurisé id/mdp    | 1·2·3·5   | JWT HS256 · bcrypt 12r · WAF · rate limit · lockout 5 échecs | Security Events | ✓ FAIT |
| HTTPS obligatoire        | 3         | Firebase HTTPS auto · Helmet HSTS max-age=31536000           | —               | ✓ FAIT |
| RGPD conforme            | 5·6·8     | DATA_EXPORT · DATA_ANONYMIZE · AES-256 · Art.15/16/17/33     | Module GDPR     | ✓ FAIT |
| RBAC — Gestion rôles     | 5·6·8·9   | checkRole() Firestore · 4 rôles · Firestore Rules deny       | Security Events | ✓ FAIT |
| Journalisation actions   | 6·7·8     | 9 events immuables · SIEM dashboard · serverTimestamp()      | 213+ events     | ✓ FAIT |
| Détection vulnérabilités | Wazu<br>h | 17 CVE identifiées · Plan correctif prioritisé               | Vuln Detector   | ✓ FAIT |
| Intégrité fichiers       | Wazu<br>h | FIM 2500+ · Rule 550 · Hash SHA-256                          | Integrity Mon.  | ✓ FAIT |
| Détection menaces        | Wazu<br>h | MITRE ATT&CK T1499/T1562 · 1600+ alertes                     | MITRE ATT&CK    | ✓ FAIT |

Toutes les exigences de sécurité du cahier des charges sont entièrement respectées et validées.

# RÉCAPITULATIF KPI — Chiffres Clés du Projet

19 / 20

|                                                      |                                                    |                                                             |                                                  |
|------------------------------------------------------|----------------------------------------------------|-------------------------------------------------------------|--------------------------------------------------|
| <div>436 420</div> <div>Security Events Wazuh</div>  | <div>100/100</div> <div>Score Dashboard App</div>  | <div>92/100</div> <div>Score DAST (12 tests)</div>          | <div>17 CVE</div> <div>8 High + 9 Medium</div>   |
| <div>8/8</div> <div>Exigences CDC §3.3</div>         | <div>9</div> <div>Types AuditLogs immuables</div>  | <div>10</div> <div>Catégories OWASP vérifiées</div>         | <div>6</div> <div>Articles RGPD couverts</div>   |
| <div>4</div> <div>Rôles RBAC moindre privilège</div> | <div>12r</div> <div>bcrypt rounds anti-brute</div> | <div>AES-256</div> <div>Chiffrement données sensibles</div> | <div>100%</div> <div>Agents Wazuh coverage</div> |

Les indicateurs montrent une application sécurisée, surveillée et conforme aux standards.

# Merci

---

## Questions & Démonstration Live

*"Le monitoring couvre intégralement le CDC §3.3 sur deux niveaux :  
monitoring applicatif (WAF · 9 audit logs Firestore · dashboard SIEM · DAST 12 tests)  
et monitoring infrastructure Wazuh (213 événements · MITRE ATT&CK · GDPR · CIS Benchmark).  
Ensemble, ils assurent une défense en profondeur conforme RGPD."*

**Amine BAHOU / Anass Akker**

PFE Bachelor Cybersécurité / Cyberdéfense — YNOV Campus 2026